EWB COURSES

Assessment 01
Security Foundations

AI-POWERED CYBERSECURITY

Student name	Sanjay Kushwaha
Batch / group	Ewb AI POWERED CYBERSECURITY INTERNSHIP
Assessment	Assessment 01 – Security Foundations
Issued	20 October 2026

All scenarios and log data are treated as fictional training evidence.

Contents and scope

- Task A – Secure a student account (25 marks)
- Task B – Analyse a suspicious message (25 marks)
- Task C – Triage a sign-in alert (25 marks)
- Task D – Review an AI security answer (25 marks)
- References and AI-use declaration

Scope: This report analyses only the fictional scenarios and synthetic evidence supplied in EWB Assessment 01. It does not test, visit, scan or make claims about any real website, sender, account or person.

Important limitation: A warning sign is a reason to verify, not proof by itself. Likewise, the absence of a warning sign does not prove that a message, URL or account is safe.

Task A – Secure a student account

A1. Five risks, assets and CIA impact

Risk	Asset at risk	CIA impact
Reuses a short password for email and the learning portal.	Email account and learning portal account.	Confidentiality: if the password is guessed or exposed on one service, another account may also be accessed. Integrity and availability may also be affected if an intruder changes account details or locks Mira out.
Approves unexpected sign-in prompts.	Learning portal account and information stored there.	Confidentiality: an unauthorised sign-in may expose grades, personal details or coursework. Integrity: the intruder may change account information or submitted work.
Postpones device and software updates.	Laptop, operating system, applications and files.	Integrity: an attacker may exploit a known weakness to alter files or install unwanted software. Availability: the device may become unusable or inaccessible.
Keeps the only project copy on one laptop.	Project files and coursework.	Availability: if the laptop is lost, damaged, stolen or fails, Mira may lose access to her project and miss a deadline. Integrity may be affected if the only copy is corrupted.
Lets a friend use the laptop while Mira's account remains signed in.	Mira's user account, email, learning portal and project files.	Confidentiality: the friend may see private messages or records. Integrity: files, settings or submissions could be changed, accidentally or deliberately.

A2. Controls, limitations and priorities

Risk addressed / control	Why it helps and limitation
Use a long, unique password for each account; store it in a reputable password manager.	Reduces password reuse and makes guessing harder. Limitation: a password manager account must itself be protected, and phishing can still trick a user into entering credentials.
Deny unexpected MFA prompts; approve only a sign-in Mira	Prevents accidental approval of an unfamiliar login. Limitation: MFA is not perfect; users can

personally started. Report repeated prompts to IT.	still be tricked, and some attacks can steal active sessions.
Install operating-system and application updates promptly, preferably with automatic updates enabled.	Fixes known security weaknesses. Limitation: updates do not prevent every attack and may require restart, compatibility checks or backup.
Keep at least one additional backup, preferably with a separate or cloud/offline copy, and test restoring it.	Provides recovery if the laptop is lost or files are damaged. Limitation: a backup can also be deleted, encrypted or become out of date if it is always connected or not checked.
Use a separate, non-administrator guest account for the friend; sign out and lock the laptop when not in use.	Separates the friend's activity from Mira's signed-in account. Limitation: a guest account does not protect files that Mira leaves shared or unlocked, and physical access still creates risk.

Priority order:

1. Stop approving unexpected sign-in prompts immediately and report repeated prompts to the college IT team. This is first because a single approval could allow an unauthorised person into the account.
2. Replace the reused short password with a long, unique password for each account, starting with email and the learning portal. Email is especially important because it may be used to reset other accounts.
3. Turn on prompt updates and create a separate backup of the project. These reduce the chance that a known device weakness or a single laptop failure causes serious loss. The backup should be made promptly; updates should then remain enabled.

The order addresses the most immediate account-takeover risk first, then reduces the chance that one exposed password compromises multiple accounts, then improves device resilience and recovery. Mira should also stop sharing her signed-in session and use a separate account for her friend.

A3. Authentication versus authorisation

Authentication is the process of checking who a user is. For example, Mira enters her learning-portal username and password and completes the required multi-factor check. The portal uses these steps to verify that the person signing in is Mira.

Authorisation happens after authentication. It decides what the authenticated user is allowed to do. For example, Mira may be allowed to view her own grades, upload her coursework and change her own profile, but she should not be allowed to view another student's private records or change a lecturer's marks. Authentication answers “Who are you?”; authorisation answers “What are you allowed to do?”

Task B – Analyse a suspicious message

B1. Five warning signs

Quoted evidence	Why it needs scrutiny
From: "awards@campus-awards.example"	The college's normal domain is campus.example, but this sender uses campus-awards.example. The similar wording may be intended to look related. The displayed sender alone does not establish who actually sent the message.
Reply-To: "help@personal-awards.example"	The reply address is on a different, personal-sounding domain from both the normal college domain and the displayed sender. Replies may go to an unrelated party.
"FINAL WARNING" and "expires in 20 minutes"	The short deadline creates pressure and discourages careful checking. Urgency is a common social-engineering warning sign.
"enter your college password and OTP"	A message asking for both a password and a one-time passcode is highly risky. The student should never disclose an OTP in a reply or unverified page.
"Do not contact the college office" and "send a photo of your identity card"	The message discourages independent verification and asks for sensitive identity information. Both requests need scrutiny and should not be followed without confirmation through an official channel.

The sample URL is not visited as part of this assessment. The message is assessed from the supplied text only.

B2. Safe verification process

4. Do not click the message link, reply, provide a password or OTP, or send an identity-card photo.
5. Open the college portal using a saved bookmark or type the college's known official address yourself. Alternatively, find the college IT or scholarship office contact details from an independently obtained official directory or previous trusted college material.
6. Ask the official office whether the scholarship notice, sender and requested action are genuine. Provide the message details to the official reporting channel without forwarding secrets or identity documents unnecessarily.

7. If the college confirms that the message is fraudulent, report it using the college's phishing-reporting process and delete or quarantine it according to college guidance.

HTTPS alone does not prove that a message is genuine. HTTPS encrypts the connection to the domain shown in the browser, but a deceptive or criminal site can also use HTTPS. A familiar display name is not proof either, because display names can be chosen by the sender and can imitate a trusted organisation. The actual domain and the message must be verified independently.

B3. If a student already entered a password and OTP

8. Contain the incident immediately. Stop interacting with the message or page. Contact the college IT/security team using an independently verified official phone number or portal. Do not send the password or OTP to anyone.
9. From a trusted device and the official college sign-in page, change the affected password to a new, unique one. If the same password was reused elsewhere, change those passwords too. Follow IT instructions if the account is locked or suspected to be under active control.
10. Ask IT to revoke active sessions and tokens, review or reset MFA methods, and check recovery email/phone details. The student should not approve further unexpected prompts.
11. Report the message and provide the time, sender details, subject and actions taken. Preserve the message and relevant evidence for IT; do not delete logs or alter evidence.
12. After containment, check recent sign-ins, account changes, forwarding rules, recovery settings and unusual activity. Continue monitoring and follow the college's incident instructions.

The student should be treated supportively and encouraged to report quickly. Prompt reporting can reduce harm.

B4. One fact that cannot be established

From the message text alone, it is not possible to establish who actually sent the email or whether the sending domain is controlled by the college, an authorised scholarship provider or an unrelated party. Additional evidence could include the full email headers and authentication results (such as SPF, DKIM and DMARC), domain-registration/ownership information, and confirmation from the college

through an independently obtained official contact. Even then, evidence should be interpreted together rather than relying on one indicator.

Task C – Triage a sign-in alert

C1. Four-point timeline: observations and interpretation

Time	Observed evidence	Interpretation (not a proven fact)
09:00–09:01	The log records a password success from 192.0.2.10 at 09:00 and an MFA approval from the same IP at 09:01.	This appears consistent with a successful sign-in from the stated usual classroom egress. The log does not by itself prove who was physically using the device.
10:14–10:15	Two password failures are recorded for student07 from 198.51.100.23.	This may indicate repeated attempts to sign in, but the IP address does not identify a person or prove where they were.
10:16–10:18	MFA denials are recorded at 10:16 and 10:17, followed by an MFA approval at 10:18 from 198.51.100.23. The student says they approved a prompt around 10:18, thinking it would stop repeated requests.	The user's statement is consistent with the recorded approval. It raises concern that an unexpected authentication request was approved.
10:20	The log records a session created from 198.51.100.23. The student says they did not initiate a sign-in after 09:05.	The timing suggests the approval may have enabled a session the student did not intend to create. This is a likely interpretation, not proof of the identity of the person or device.

C2. Likely explanation, alternative and checks

Likely explanation: Someone other than the student may have been attempting to access the account. The repeated password failures and MFA requests may have been part of an attempt to obtain access. The student then approved an unexpected MFA prompt at about 10:18, after which a session was created at 10:20. This pattern is consistent with an MFA-prompt or “push fatigue” attack, but the supplied log does not prove the attacker's identity or exactly how the password attempts occurred.

Alternative explanation: The activity could have resulted from a legitimate but misidentified sign-in attempt, such as a student's old device, a VPN/proxy, a shared network or an authentication service retrying requests. The student's memory of the

time may also be incomplete. This alternative should be checked rather than assumed.

Two useful checks:

- Review the identity provider's detailed authentication records for request IDs, device/browser information, user agent, session/token details, MFA method and exact prompt timestamps. Compare them with the student's known devices and activity.
- Ask the student, through the official IT process, whether they recognise the device, browser, application or session. Check account activity, password-reset events, recovery-setting changes and other security alerts around the same period. Treat IP geolocation as contextual evidence only, not proof of a person's identity.

C3. Three prioritised actions for the authorised IT team

13. Protect the account immediately: contact the student through an official channel, reset the password using the approved process, revoke active sessions/tokens, review MFA registrations and recovery settings, and require the student to deny unrecognised prompts. Consider temporarily restricting sign-in while the account is secured.
14. Preserve evidence before routine retention removes it: export the relevant authentication, MFA and session logs; record timestamps and time zone; preserve request/session identifiers and relevant endpoint evidence; and document who collected the evidence and when. Do not delete or modify the logs.
15. Investigate scope and recover safely: review other recent sign-ins and affected services, look for changes to mailbox forwarding, recovery details or account permissions, and check for additional affected accounts. Restore normal access only after the account is secured and the incident is documented.

These actions are for the authorised IT team, not for an unauthorised student to perform on systems they do not administer.

C4. Incident summary (60–100 words)

The synthetic logs show a successful password and MFA sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:15, password attempts from a

different documentation IP failed; two MFA requests were denied, then one was approved at 10:18. The student says they did not initiate a sign-in and approved a prompt by mistake. A session was created at 10:20. This is consistent with possible unauthorised access, but the IP does not identify a person. IT should secure the account, revoke sessions and preserve logs.

Task D – Review an AI security answer

D1. Five unsafe or unsupported claims/actions and corrections

AI output claim/action	Correction and reason
"The email is safe because it uses HTTPS."	Incorrect. HTTPS encrypts the connection to a domain; it does not prove that the domain or message belongs to the college. Verify through a known official portal or contact and inspect the actual domain.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported. The logs show events associated with a documentation IP address, not the identity of a person or how a password was obtained. A different IP alone is not proof of an attacker. Correlate detailed authentication, device and session evidence.
"MFA prevents every account compromise."	Incorrect. MFA reduces risk but is not a guarantee. A user may approve an unexpected prompt, or an attacker may obtain a session token or exploit another weakness. Users should deny unexpected prompts and report them.
"Delete the suspicious logs."	Unsafe. Logs are evidence needed to understand scope, timing and cause. Preserve relevant records and follow the authorised incident-response and retention process; do not delete or alter them.
"Send the student's password to support so they can test it."	Unsafe and unnecessary. Support staff should never need the student's password or OTP. The student should change a compromised password through the official process, and IT should use approved administrative tools and logs.

D2. Better prompt for an AI tool

Analyse only the fictional message and synthetic sign-in log evidence provided below. Do not visit, scan or interact with any URL or system. Separate directly observed facts from interpretations and assumptions. Identify warning signs and explain why each needs scrutiny. For the sign-in timeline, do not identify a person from an IP address and do not claim certainty where the evidence is incomplete. Recommend safe, prioritised

actions for the account owner and authorised IT team. Do not ask for, repeat or include passwords, OTPs, identity documents or other secrets. State what cannot be established from the supplied evidence and list additional evidence that would help. Use cautious language and identify any claims that need verification against trustworthy references.

D3. Corrected security advice (100–150 words)

Do not trust the scholarship message just because its link uses HTTPS or its sender name looks familiar. Do not open the link, reply, provide a password or OTP, or send an identity-card photo. Verify the notice by opening the college portal through a saved bookmark or by contacting the scholarship office using details from an independent official source. The sign-in log shows repeated failures, MFA denials, an approval at about 10:18 and a session at 10:20; it does not identify a person or prove how credentials were obtained. The student should report the unexpected prompt immediately. Authorised IT staff should secure the account, revoke sessions, review MFA and recovery settings, preserve logs and check for further suspicious activity.

D4. AI-use declaration and evidence notes

AI-use declaration: ChatGPT was used to help organise the assessment responses, explain security concepts in plain language and prepare this draft report. The supplied EWB assessment scenario and fictional evidence were used as the basis. No live websites were visited, no public systems were scanned, no phishing messages were sent, and no real passwords, OTPs or other people's personal data were used. The student should review, verify and edit the draft so the final submission reflects their own understanding and follows EWB's rules.

Evidence/reference note 1 – CISA Secure Our World: Used as a general reference for practical account security, strong unique passwords, multi-factor authentication, software updates and recognising/reporting phishing. The recommendations in this report are consistent with those basic security practices.

Evidence/reference note 2 – NIST AI 600-1, Generative Artificial Intelligence Profile: Used as a reference for treating AI output critically, checking claims against evidence, recognising that AI can produce inaccurate or unsupported statements, and communicating uncertainty. AI output is not treated as proof.

References

Cybersecurity and Infrastructure Security Agency (CISA). Secure Our World. https://www.cisa.gov/secure-our-world

National Institute of Standards and Technology (NIST). (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

EWB Courses. (20 October 2026). Assessment 01: Security Foundations, AI-Powered Cybersecurity, pages 1–4. Supplied assessment brief.